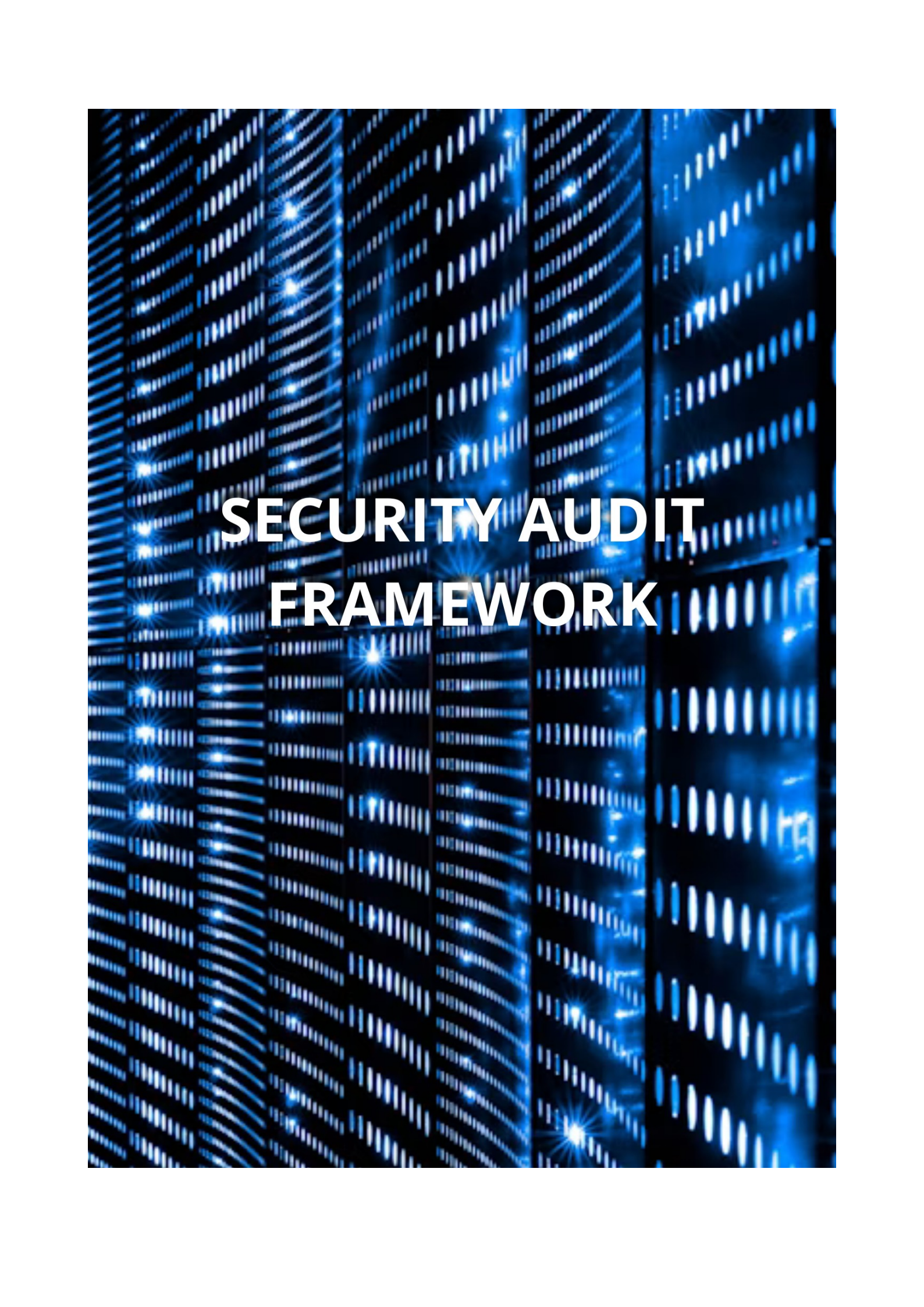




SECURITY AUDIT FRAMEWORK

Project: Security Audit Framework

Data: 29 de july 2026

Revisore: Guillermo Rodríguez Pérez.

Indice:

1. Sintesi del progetto
2. Architettura del sistema
3. Componenti implementati
4. Migliori pratiche ingegneristiche
 - 4.1 Matrice KPI e Requisiti di Sicurezza
5. Stato del progetto e conclusioni
 - 5.1 Attività completate
 - 5.2 Problematiche riscontrate
 - 5.3 Punti in sospeso (Roadmap)
6. Roadmap Versione 2.0
 - 6.1 Evoluzione Architetturale
 - 6.2 Moduli di Analisi Avanzata
 - 6.3 Qualità e Automazione
7. Allegati

1- Sintesi del progetto:

Il progetto consiste nello sviluppo di un framework di audit passivo in Python, progettato per valutare lo stato di sicurezza dei domini web senza generare traffico di attacco intrusivo. Il sistema è strutturato secondo un'architettura modulare che separa la logica di scansione, la gestione dei rischi e la generazione dei report.

2- Architettura del sistema:

Il progetto è organizzato secondo la seguente struttura di directory:

- `core/`: Contiene la logica centrale della scansione e i moduli di analisi.
- `reports/`: Gestisce la logica di presentazione e archiviazione dei risultati.
- `tests/`: Suite di test unitari per garantire l'affidabilità del codice.
- `main.py`: Punto di ingresso e coordinatore del framework.

3- Componenti implementati:

Gestione dell'ambiente: implementazione di venv per garantire l'isolamento delle dipendenze.

- **Motore di scansione (`core/scanner.py`):** include risoluzione DNS (SPF/DMARC), analisi TLS/SSL, analisi automatizzata delle intestazioni di sicurezza HTTP e rilevamento dei CMS.
- **Gestione dei rischi (`core/scoring.py`):** centralizzazione della logica di gravità (0-10) basata sui risultati rilevati.
- **Report (`reports/generator.py`):** generazione dei risultati nei formati `JSON` e `Markdown`.

4- Migliori pratiche di ingegneria

Il design del prototipo ha seguito un approccio metodologico rigoroso, garantendo la coerenza tra gli obiettivi di sicurezza, l'uso etico delle risorse e la conformità ai requisiti tecnici definiti nelle specifiche di progetto.

4.1- Matrice KPI e Requisiti di Sicurezza

Per definire l'ambito di applicazione, è stata sviluppata una matrice dei KPI (Key Performance Indicators) che correla i controlli tecnici al rischio operativo e alla severità potenziale. Inoltre, in ottemperanza ai requisiti di sicurezza del punto 11, il tool è stato configurato per operare in modo tracciabile: ogni richiesta HTTP include esplicitamente il `User-Agent` identificativo `Hirooks-Security-Baseline-Prototype/0.1` e implementa policy di `timeout` su tutte le connessioni per prevenire abusi o crash. Tale configurazione è implementata nel modulo `core/scanner.py`, all'interno della funzione `scan_headers`.

KPI	Area	Obiettivo	Metodo tecnico	Rischio	Gravità	Output	Raccomandazione
TLS/HTTPS	Trasporto	Crittografia	Handshake TLS	Bassa	Medio	Stato	Abilita TLS 1.2+
HSTS	Endpoint	Integrità	Ispezione HTTP	Bassa	Medio	Intestazione	Applica HSTS
SPF/DMAR C	Posta	Anti-spoofing	Query DNS	Bassa	Medio	Record	Configura DNS
.env / Git	Configurazione	Privacy	Audit passivo	Medio	Critica	Codice HTTP	Blocca l'accesso
Robots.txt	Governance	Crawler basato su IA	Analisi sintattica	Bassa	Informazioni	Regola	Policy esplicita

5- Stato del progetto e conclusioni

Il framework include un'architettura predisposta per l'integrazione, in futuro, di moduli per il rilevamento di file sensibili (`.env`, backup) e per l'analisi euristica del comportamento.

5.1- Attività completate

- Sviluppo dell'infrastruttura del framework (`SecurityScanner`).
- Implementazione della generazione di report in formato JSON e Markdown.
- Convalida del sistema tramite suite di test unitari (`unittest`).
- Esecuzione di un'auditoria reale sul dominio target (`asociaciondigitalcanaria.es`).

5.2- Problematiche riscontrate

- **Configurazione ambiente:** Difficoltà iniziali nell'attivazione dell'ambiente virtuale (venv), risolte attraverso la corretta verifica dei percorsi dei file binari.
- **Interfaccia CLI:** Necessità di gestire i parametri di input (`--url`) per rendere il tool dinamico, risolta tramite l'integrazione del modulo `argparse`.

5.3- Punti in sospeso (Roadmap)

Il framework è stato progettato con un'architettura modulare che ne facilita l'espansione. I seguenti moduli sono già stati predisposti nella struttura logica (attualmente in stato "PLANNED" nel codice), come documentato nell'Allegato A:

- Espansione della base di firme di vulnerabilità.
- **Moduli di analisi avanzata (v2.0):**
 - **Rilevamento file sensibili:** Implementazione dei controlli per identificare file di configurazione (.env), backup e directory esposte.
 - **Analisi euristica Bot/IA:** Integrazione di algoritmi per il rilevamento di comportamenti non umani o attività bot.
(Nota: La struttura del codice di questi moduli è visibile in dettaglio negli Allegati).
- **Ottimizzazione e Performance:**
 - Espansione della base di dati delle firme di vulnerabilità per aumentare la precisione dell'audit.
 - Implementazione di tecniche di scansione asincrona per migliorare la velocità su grandi volumi di domini.

6- Roadmap Versione 2.0

In conformità con quanto suggerito nelle specifiche di progetto, è stata delineata una visione preliminare per la Versione 2.0, volta a trasformare il prototipo attuale in uno strumento di monitoraggio più robusto e integrato.

6.1 Evoluzione Architetture

- **Backend FastAPI:** Migrazione verso un'architettura asincrona per migliorare la scalabilità e consentire l'esposizione di API di audit.
- **Persistenza Dati:** Implementazione di un database SQLite per mantenere lo storico degli audit e permettere il confronto temporale tra scansioni.

6.2 Moduli di Analisi Avanzata

- **Intelligence Specifica per CMS:** Sviluppo di fingerprinting dedicato per le piattaforme più diffuse (WordPress, PrestaShop, Magento), in linea con le raccomandazioni del tutor.
- **Integrazione API esterne:** Valutazione dell'integrazione di feed di sicurezza per arricchire il punteggio (scoring) con dati di vulnerabilità aggiornati.

6.3 Qualità e Automazione

- **Sistema di Notifiche:** Implementazione di alert automatici in caso di peggioramento significativo dello score di sicurezza.
- **Suite di Test:** Espansione del framework di testing per garantire una copertura completa delle nuove funzionalità.
Nota: Queste direttrici rappresentano una pianificazione strategica preliminare e sono in attesa di validazione tecnica per la definizione dei dettagli implementativi finali.

7- Allegati

Struttura del progetto

```
(venv)-(guillermo@vbox)-[~/proyecto_seguridad]
$ tree -I "__pycache__|venv|..git"
.
├── auditoria_seguridad
│   ├── core
│   │   ├── cms_detector.py
│   │   ├── __init__.py
│   │   ├── scanner.py
│   │   ├── scoring.py
│   │   └── utils.py
│   ├── main.py
│   ├── report.json
│   ├── report.md
│   ├── reports
│   │   ├── generator.py
│   │   ├── __init__.py
│   │   ├── requirements.txt
│   │   ├── test_cms.py
│   │   └── tests
│   │       ├── __init__.py
│   │       └── test_scanner.py
│   └── README.md
5 directories, 15 files
```

Esecuzione del framework

```
(venv)-(guillermo@vbox)-[~/proyecto_seguridad/auditoria_seguridad]
$ python3 main.py --url https://asociaciondigitalcanaria.es
[*] Iniciando framework de auditoria para: https://asociaciondigitalcanaria.es
[DEBUG] Formate recibido: 'md'
[+] Report Markdown generado: report.md
[DEBUG] Formate recibido: 'json'
[+] Report JSON generado: report.json
[+] Auditoria finalizada exitosamente.
[+] Reporte generado en formato: MD
```

Rapporto finale generato

```
(venv)-(guillermo@vbox)-[~/proyecto_seguridad/auditoria_seguridad]
$ cat report.md
# Report di audit di sicurezza

## Risultati della scansione

- **Test: DNS Security (SPF/DMARC)**
- **Stato: FAIL**
- **Gravità: CRITICAL**
- **Punti: 0**

- **Test: TLS/SSL**
- **Stato: PASS**
- **Gravità: INFO**
- **Punti: 10**

- **Test: Security Headers**
- **Stato: PASS**
- **Gravità: INFO**
- **Punti: 8.3**

- **Test: Sensitive Files**
- **Stato: PLANNED**
- **Gravità: INFO**
- **Punti: 0**

- **Test: Bot/IA Detection**
- **Stato: PLANNED**
- **Gravità: INFO**
- **Punti: 0**

- **Test: CMS Fingerprinting**
- **Stato: PASS**
- **Gravità: N/A**
- **Punti: 0
```

```
(venv)-(guillermo@vbox)-[~/proyecto_seguridad/auditoria_seguridad]
$ cat report.json
[
  {
    "test": "DNS Security (SPF/DMARC)",
    "status": "FAIL",
    "score": 0,
    "severity": "CRITICAL",
    "details": "SPF: FAIL, DMARC: FAIL"
  },
  {
    "test": "TLS/SSL",
    "status": "PASS",
    "details": "Certificato valido e crittografia attiva",
    "score": 10,
    "severity": "INFO"
  },
  {
    "test": "Security Headers",
    "status": "PASS",
    "score": 8.3,
    "severity": "INFO",
    "details": "Intestazioni trovate: 5/6"
  },
  {
    "test": "Sensitive Files",
    "status": "PLANNED",
    "details": "Pending implementation",
    "score": 0,
    "severity": "INFO"
  },
  {
    "test": "Bot/IA Detection",
    "status": "PLANNED",
    "details": "Pending implementation",
    "score": 0,
    "severity": "INFO"
  },
  {
    "test": "CMS Fingerprinting",
    "status": "PASS",
    "result": "WordPress",
    "details": "Firme rilevate: wp-content, wp-includes, wp-json, wp-login.php. Metodologia di analisi: Fingerprinting passivo."
  }
]
```

Test unitari

```
(venv)-(guillermo@vbox)-[~/proyecto_seguridad/auditoria_seguridad]
$ python3 -m unittest discover
— Avvio del test di rilevamento CMS —
Test: CMS Fingerprinting
Status: PASS
Risultato: WordPress
Details: Firme rilevate: wp-content, wp-includes, wp-json, wp-login.php. Metodologia di analisi: Fingerprinting passivo.
..
Ran 2 tests in 0.001s

OK
```

Evidenza strutturale dei moduli futuri

```
def scan_sensitive_file(self):
    """ IN ATTESA: Implementazione relativa ai file sensibili (.env, backup, configurazione).
    Modulo previsto per la versione 2.0"""
    return {"test": "Sensitive Files", "status": "PLANNED", "details": "Pending implementation", "score": 0, "severity": "INFO"}

def scan_bot_ai_behavior(self):
    """ DA FARE: Implementazione del rilevamento euristico di bot/IA in attesa.
    Modulo previsto per la versione 2.0"""
    return {"test": "Bot/IA Detection", "status": "PLANNED", "details": "Pending implementation", "score": 0, "severity": "INFO"}
```

```
def run_audit(self):
    """Esegue tutti i test e restituisce l'elenco dei risultati"""
    audit_data = []
    audit_data.append(self.scan_dns())
    audit_data.append(self.scan_tls())
    audit_data.append(self.scan_headers())
    # Nuovi punti pianificati integrati nel flusso
    audit_data.append(self.scan_sensitive_files())
    audit_data.append(self.scan_bot_ai_behavior())
```

Verifica dei record memorizzati nel database

```

(guillermo@vbox) ~/proyecto_seguridad/auditoria_seguridad
$ python3 main.py --url https://asociaciondigitalcanaria.es
[+] Inicializando framework de auditoria para: https://asociaciondigitalcanaria.es
[DEBUG] Formateo recibido: 'md'
[+] Reporte Markdown generado: report.md
[DEBUG] Formateo recibido: 'json'
[+] Reporte JSON generado: report.json
[+] Auditoria finalizada exitosamente.
[+] Reporte generado en formato: MD

(guillermo@vbox) ~/proyecto_seguridad/auditoria_seguridad
$ sqlite3 scanner_history.db "SELECT * FROM audit_results;"
1|asociaciondigitalcanaria.es|DNS Security (SPF/DMARC)|FAIL|0.0|2026-07-31 09:19:21
2|asociaciondigitalcanaria.es|TLS/SSL|PASS|10.0|2026-07-31 09:19:21
3|asociaciondigitalcanaria.es|Security Headers|PASS|8.3|2026-07-31 09:19:21
4|asociaciondigitalcanaria.es|Sensitive Files|PLANNED|0.0|2026-07-31 09:19:21
5|asociaciondigitalcanaria.es|Bot/IA Detection|PLANNED|0.0|2026-07-31 09:19:21
6|asociaciondigitalcanaria.es|DNS Security (SPF/DMARC)|FAIL|0.0|2026-07-31 09:24:16
7|asociaciondigitalcanaria.es|TLS/SSL|PASS|10.0|2026-07-31 09:24:16
8|asociaciondigitalcanaria.es|Security Headers|PASS|8.3|2026-07-31 09:24:16
9|asociaciondigitalcanaria.es|Sensitive Files|PLANNED|0.0|2026-07-31 09:24:16
10|asociaciondigitalcanaria.es|Bot/IA Detection|PLANNED|0.0|2026-07-31 09:24:16
11|asociaciondigitalcanaria.es|CMS Fingerprinting|PASS|0.0|2026-07-31 09:24:16

(guillermo@vbox) ~/proyecto_seguridad/auditoria_seguridad
$

```

Visualizzazione della cronologia di audit tramite l'interfaccia a riga di comando

```

(guillermo@vbox) ~/proyecto_seguridad/auditoria_seguridad
$ python3 main.py --history

--- Storico Audit per ---
[2026-07-31 09:24:16] DNS Security (SPF/DMARC) | FAIL | Punteggio: 0.0
[2026-07-31 09:24:16] TLS/SSL | PASS | Punteggio: 10.0
[2026-07-31 09:24:16] Security Headers | PASS | Punteggio: 8.3
[2026-07-31 09:24:16] Sensitive Files | PLANNED | Punteggio: 0.0
[2026-07-31 09:24:16] Bot/IA Detection | PLANNED | Punteggio: 0.0
[2026-07-31 09:24:16] CMS Fingerprinting | PASS | Punteggio: 0.0
[2026-07-31 09:19:21] DNS Security (SPF/DMARC) | FAIL | Punteggio: 0.0
[2026-07-31 09:19:21] TLS/SSL | PASS | Punteggio: 10.0
[2026-07-31 09:19:21] Security Headers | PASS | Punteggio: 8.3
[2026-07-31 09:19:21] Sensitive Files | PLANNED | Punteggio: 0.0

(guillermo@vbox) ~/proyecto_seguridad/auditoria_seguridad
$ python3 main.py --history --url https://asociaciondigitalcanaria.es

--- Storico Audit per https://asociaciondigitalcanaria.es ---
[2026-07-31 09:24:16] DNS Security (SPF/DMARC) | FAIL | Punteggio: 0.0
[2026-07-31 09:24:16] TLS/SSL | PASS | Punteggio: 10.0
[2026-07-31 09:24:16] Security Headers | PASS | Punteggio: 8.3
[2026-07-31 09:24:16] Sensitive Files | PLANNED | Punteggio: 0.0
[2026-07-31 09:24:16] Bot/IA Detection | PLANNED | Punteggio: 0.0
[2026-07-31 09:24:16] CMS Fingerprinting | PASS | Punteggio: 0.0
[2026-07-31 09:19:21] DNS Security (SPF/DMARC) | FAIL | Punteggio: 0.0
[2026-07-31 09:19:21] TLS/SSL | PASS | Punteggio: 10.0
[2026-07-31 09:19:21] Security Headers | PASS | Punteggio: 8.3
[2026-07-31 09:19:21] Sensitive Files | PLANNED | Punteggio: 0.0

```

Ejecución de la rutina de limpieza del historial de auditoría

```

(guillermo@vbox) ~/proyecto_seguridad/auditoria_seguridad
$ python3 main.py --clear_history
¿Sei sicuro di volver eliminare l'intera cronologia? (s/n)s

[+] Cronologia di audit eliminata correttamente.

```

Esecuzione dell'audit tramite l'interfaccia API interattiva

```

(guillermo@vbox) ~/proyecto_seguridad/auditoria_seguridad
$ uvicorn main:app --host 0.0.0.0 --port 8000 --reload
INFO: Will watch for changes in these directories: ['/home/guillermo/proyecto_seguridad/auditoria_seguridad']
INFO: Uvicorn running on http://0.0.0.0:8000 (Press CTRL+C to quit)
INFO: Started reloader process [312958] using StatReload
INFO: Started server process [312960]
INFO: Waiting for application startup.
INFO: Application startup complete.
INFO: 127.0.0.1:41286 - "GET /docs HTTP/1.1" 200 OK
INFO: 127.0.0.1:41286 - "GET /openapi.json HTTP/1.1" 200 OK
[DEBUG] Formateo recibido: 'md'
[+] Reporte Markdown generado: report.md
[DEBUG] Formateo recibido: 'json'
[+] Reporte JSON generado: report.json
INFO: 127.0.0.1:48684 - "POST /audit HTTP/1.1" 200 OK

```

127.0.0.1:8000/docs#/default/run_audit_audit_post

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

POST /audit Run Audit

Parameters

CancelReset

No parameters

Request body required

application/json

Edit Value | Schema

```
{  "url": "https://www.google.com"}
```

Execute

Clear